מספר התלמיד הנבחן
רשום את כל תשע הספרות

הדבק כאן את מדבקת הנבחן

האוניברסיטה הפתוחה

ט' באדר תשפ"ג

2

מס' שאלון - 538

במרץ 2023

סמסטר 2023א

מס' מועד 92

4 / 20940

שאלון בחינת גמר

20940 - מבוא לאבטחת המרחב המקוון

משך בחינה: 3 שעות

בשאלון זה **4** עמודים

מבנה הבחינה:

עליכם לענות על ארבע מתוך חמש השאלות.
יש להקפיד על כתב יד קריא.
השתדלו להתחיל כל תשובה בדף חדש.

בהצלחה.

חומר עזר:
מותר לשימוש מחשבון מדעי שלא אוצר מידע.

בהצלחה !!!

אינכם חייבים
להחזיר את השאלון לאוניברסיטה הפתוחה

שאלה 1

נתונה מערכת עם 3 משתמשים: U1, U2, U3 ו4 קבצים F1, F2, F3, F4.

משתמש U1 יכול לקרוא מ-F1 ולכתוב לכל הקבצים

משתמש U2 יכול לקרוא מכל הקבצים ולכתוב ל-F2 ו-F4

משתמש U3 יכול לקרוא מ-F1 ומ-F3 ולכתוב על F2 על F3 ועל-F4

א. רשמו את מטריצת הגישה.

ב. רשמו את המטריצה בצורה של ACL ובצורה של –C-List.

ג. האם ניתן לייצג מטריצה זו ב-UNIX (כלומר ב-UNIX קלסי עם 9 ביטים בלבד)? הראו כיצד או הסבירו מדוע לא.

ד. האם ניתן לייצג מטריצה זו ב-WINDOWS? הראו כיצד או הסבירו מדוע לא.

ה. האם יכולה להיות זרימת מידע לא-חוקית במערכת? הראו כיצד או הסבירו מדוע לא.

ו. האם יש מודל BLP מתאים למערכת? אם כן, הראו השמה של מחלקות הגנה למשתמשים וקבצים המתאימה למודל. אם לא, הסבירו מדוע.

ז. האם ייתכן ערוץ נסתר במערכת? אם כן, הראו דוגמה לערוץ שכזה. אם לא, הסבירו מדוע.

ח. הראו שימוש אפשרי במנגנון high water mark במערכת זו.

*** פרטו כל הנחה שאתם מניחים**

שאלה 2

א. (12 נק') כדי לקבל הגנה טובה יותר מפני התקפות אופליין על סיסמאות הוצעה ההצעה הבאה: במקום להפעיל את פונקציית הגיבוב (HASH) מספר קבוע של פעמים, נבצע t איטרציות של גיבוב, והמשתנה t לא יישמר בקובץ הסיסמאות (או בכלל). במקום זאת, בפעם הראשונה שבה נרשם המשתמש למערכת יוגדר t (ע"י המשתמש או בהתאם למדיניות מסוימת) והסיסמה תגובב t פעמים ותישמר בקובץ הסיסמאות (עם SALT). בעת כניסה למערכת המשתמש יספק את הסיסמה (בלבד) והתוכנית המבצעת אימות תבצע גיבוב של הסיסמה פעם אחת ותשווה מול הערך השמור. אם יש התאמה – תאושר הכניסה, אחרת היא תבצע גיבוב נוסף ותשווה שוב. תהליך זה יימשך עד למציאת התאמה או עד שהמשתמש ילחץ Ctrl-C כדי לעצור את התהליך. הסבירו כיצד משתמש חוקי שהכניס סיסמה שגויה יידע שהוא עשה טעות. הסבירו במפורט כיצד תתבצע התקפת אופליין כעת, ומדוע שיטה זו משפרת את ההגנה מול התקפות אופליין. חוו דעתכם על השיטה.

ב. (8 נק') נתונה השגרה הבאה המקבלת שם משתמש, מבקשת ממנו את סיסמתו, ובודקת אם הסיסמה נכונה. בהנחה שהמערכת מפעילה את כל אמצעי ההגנה מפני buffer-overflow המפורטים בהמשך, האם תוקף שאין לו סיסמה מתאימה יכול להזדהות כמשתמש חוקי?

```
int authenticate_user(uname)
{
  int auth = 0;
  char pwd[32]; //a buffer of size 32
  printf("enter password: ");
  gets(pwd);
  if(check_password(uname, pwd)) // a method that checks
                                 // if the password is correct
  {
    auth = 1;
  }
  return auth;
}
```

אמצעי הגנה:

שתילת ערך לפני כתובת החזרה בזמן קומפילציה - CANARY

סימון מחסנית כ "לא להרצה" - DEP (NX)

רנדומיזציה של מיקומי פונקציות מערכת ידועות - ASLR

רנדומיזציה של מיקום המחסנית - STACK RANDOMIZATION

אין קשר בין סעיף א' לסעיף ב'.

שאלה 3

הסבירו חמישה מתוך ששת המושגים הבאים. יש ללוות בדוגמה כשמתאים.

1. SQL Injection
2. Phishing
3. Kerberos
4. זיהוי ביומטרי
5. סוס טרויאני
6. SSL Handshake Protocol

שאלה 4

בשאלה זו נתייחס לפרוטוקול דיפי הלמן ליצירת מפתח משותף. כידוע פרוטוקול זה חשוף להתקפת האיש שבאמצע. להלן שלוש אפשרויות לשיפור הפרוטוקול כך שלא יהיה חשוף להתקפה זו. עבור כל אפשרות ציינו אם היא אכן השיגה את מטרתה או לא. הסבירו במפורט מדוע כן או מדוע לא.

נזכיר: בפרוטוקול הרגיל אליס שולחת g^a ובוב שולח g^b. המפתח המשותף הוא g^{ab} (כמובן שכל החישובים כאן ובהמשך הם מודולו p). להלן נסמן מפתח משותף זה ב-s_key.

נסיון שיפור 1:

אליס שולחת g^a

בוב שולח g^b וגם $F_{s_key}(g^a||g^b)$, כאשר F_{s_key} מייצגת פונק' MAC בטוחה

אליס שולחת g^a וגם $F_{s_key}(g^b||g^a)$

נסיון שיפור 2 :

אליס שולחת $E_W(g^a)$ - הצפנה סימטרית של g^a עם מפתח הנגזר מסיסמה הידועה לשני הצדדים

בוב שולח $E_W(g^b)$ - הצפנה סימטרית של g^b עם אותו המפתח

נסיון שיפור 3 :

אליס שולחת g^a וכן $S_{RSA}(KR_a,g^a)$ - הצפנה של g^a במפתח הפרטי של אליס (חתימת RSA)

בוב שולח g^b וכן $S_{RSA}(KR_b,g^b)$ - הצפנה של g^b במפתח הפרטי של בוב (חתימת RSA)

(המפתחות הציבוריים של שני הצדדים ידועים ונכונים).

שאלה 5

כתבו נכון/לא נכון יש והסבירו **<u>בקצרה</u>** את תשובותיכם (2-3 משפטים).

א. Risk Analysis עוזר בקבלת החלטות על מנגנוני הגנה בארגון

ב. salt יכול להגן מפני התקפות אונליין

ג. סיסמה השמורה עם salt זה דוגמה ל-Two Factor Authentication

ד. אם תמוגר בעיית ה-Buffer Overflow מן העולם אז לא תהיינה יותר תולעים.

ה. אנטי וירוס יכול לגלות רק וירוסים ידועים

ו. תולעת שרק מתפשטת ברחבי האינטרנט יכולה לגרום נזק

ז. תפקידו של firewall זהה לשל intrusion detection system

ח. Firewall **Stateless** יכול לאכוף את החוק הבא : אפשר **כל תעבורת TCP היוצאת** מן הארגון, אך אפשר **רק תעבורת TCP הנכנסת** לארגון **כתגובה** לתעבורה שהחלה מתוך הארגון.

ט. ב-PGP אין צורך ב- CA שכל המשתמשים סומכים עליו

י. התקפת XSS עושה שימוש ב-Buffer Overflow

ב ה צ ל ח ה!